

Table of Contents

1	Executive Summary & Problem Statement
2	Organisational Context
3	Product Vision
4	Target Users & Personas
5	Core User Journey
6	Feature Requirements
7	AI Integration Requirements
8	Governance & Compliance Requirements
9	Security Requirements
10	AI Findings Schema
11	Audit Log Schema
12	Success Criteria
13	Out of Scope
14	Assumptions & Open Questions

1 Executive Summary & Problem Statement

The Core Problem

Finance and audit teams within large faith-based and non-profit organisations routinely evaluate internal controls across dozens of operational units. This evaluation involves reading process descriptions, identifying control weaknesses, and documenting findings — work that is time-intensive, heavily reliant on individual expertise, and difficult to standardise at scale.

The review process is almost entirely manual today. An auditor reads a process document, applies professional judgement to identify gaps, writes findings by hand, and submits them through a review chain. Three structural problems emerge from this:

- **Inconsistency:** Different auditors identify different gaps in the same process. Without a structured framework applied uniformly, coverage quality varies by individual.
- **Speed:** A thorough review of a single process description can take hours. When dozens of units require evaluation within an audit cycle, scope is inevitably compressed.
- **Traceability:** When findings are produced manually, the connection between a specific text passage in a process document and the resulting finding is rarely captured. This makes retrospective review and appeals difficult.

Why AI is the Right Tool Here

Large language models are particularly well suited to this class of problem. Identifying control gaps requires reading unstructured natural language, mapping described activities to a conceptual framework (control types, risk categories, segregation-of-duties principles), and generating structured, actionable output. This is precisely what modern LLMs do well — provided they are given a rigorous prompt framework and operate within a human-in-the-loop workflow.

Key Insight: ControlGuard AI does not replace auditor judgement. It applies a consistent analytical framework at machine speed, surfaces candidate findings with supporting evidence and confidence scores, and presents them to a human reviewer who makes every final decision. The AI accelerates discovery; the human owns the conclusion.

2 Organisational Context

The Church Finance & Audit Environment

The Church of Jesus Christ of Latter-day Saints operates a decentralised financial structure across thousands of local units worldwide. Each unit — a ward, branch, or stake — handles donations, disbursements, and reimbursements independently, governed by a set of standardised internal controls defined at the institutional level.

The Frankfurt finance department operates as a regional oversight body responsible for supporting, monitoring, and evaluating compliance with these controls across local units in its jurisdiction. Audit cycles are periodic, and the department must evaluate a significant number of unit processes within each cycle.

Key Control Concepts in This Context

Segregation of Duties (SoD)

No single individual should have end-to-end control over a financial process. For example, the person who requests a reimbursement should not also be the person who approves and processes it. SoD violations are among the highest-priority findings in any internal controls review.

Preventive Controls

Controls designed to stop an error or irregularity before it occurs. Examples include dual-approval requirements, spending limits enforced by policy, and access restrictions that prevent unauthorised transactions from being initiated.

Detective Controls

Controls designed to identify errors or irregularities after they have occurred. Examples include monthly reconciliations, transaction reports reviewed by a second party, and exception alerts triggered by unusual activity.

Corrective Controls

Controls that remediate identified problems. Examples include procedures to reverse incorrect transactions, escalation protocols, and mandatory retraining following a control failure.

Control Gap

A point in a process where a required control is absent, insufficient, or has been bypassed. Gaps may be structural (the process was never designed with the control) or operational (the control exists in policy but is not being followed).

Audit Traceability

The ability to connect a finding back to its source evidence — the specific text, transaction, or document that gave rise to it. Traceability is essential for findings to be defensible, appealable, and useful as a basis for remediation.

3 Product Vision

Vision Statement

ControlGuard AI is an AI-assisted internal controls evaluation assistant that enables finance and audit professionals to upload process descriptions and receive structured, evidence-backed findings — organised by risk level and control category — which they can review, accept, edit, or dismiss within a governed human-in-the-loop workflow. Every decision is logged, every AI output is traceable, and every exported report is a complete audit record.

What Success Looks Like

A finance auditor at the Frankfurt department opens ControlGuard AI, creates a new review session for Ward Frankfurt-West's disbursement process, uploads a two-page Word document describing the process, and within 30 seconds has a structured list of candidate findings — each with a risk rating, a confidence score, supporting evidence quoted from the document, and a recommended control improvement.

The auditor reviews each finding. They accept three, edit one to add local context, and dismiss one they know to be already addressed by a compensating control not described in the document. They add a note explaining the dismissal. They finalise the session and export a PDF report that contains the full finding log, the AI's original outputs, and every decision the auditor made — with timestamps and reviewer identity on each action.

The entire review — upload to export — takes under 10 minutes instead of two hours.

Strategic Differentiators

Structured AI Output

Findings are not free-text summaries. They conform to a strict schema with typed fields, confidence scores, and evidence links, making them machine-processable and consistently comparable across sessions.

Confidence-Gated Review

Findings below a defined confidence threshold cannot be auto-accepted. They are flagged for mandatory human review, preventing the system from producing ungoverned low-quality outputs.

Complete Audit Trail

Every action in the system — AI call inputs, AI call outputs, reviewer decisions, edits, and dismissals — is written to an immutable log that can be exported alongside the final findings report.

Evidence Traceability

Each finding links to the specific passage in the source document that triggered it, giving reviewers immediate access to the justification and making the AI's reasoning transparent.

4 Target Users & Personas

The Finance Auditor	Primary User
A member of the Frankfurt finance team responsible for conducting periodic internal controls evaluations of local units. Has solid domain knowledge of Church financial policies and control frameworks but limited time per review cycle.	
Core Needs	Pain Points
• Rapid first-pass analysis of process documents • Clear, structured findings she can review and act on quickly • Confidence that AI suggestions have been validated before inclusion in reports • An exportable report she can submit through official channels	• Reading the same types of process descriptions repeatedly and identifying the same categories of gaps manually • Having to write finding language from scratch for each report • Difficulty tracking which documents have been reviewed and by whom

The Compliance Supervisor	Secondary User / Report Consumer
A senior member of the finance department who reviews completed audit sessions and exported reports. Primarily concerned with quality, consistency, and traceability of findings across multiple auditors and sessions.	
Core Needs	Pain Points
• Evidence that findings are grounded in source documents • Visibility into reviewer decisions and any overrides of AI recommendations • A consistent report format across all sessions	• Inconsistent finding quality across different team members • No visibility into how findings were reached

5 Core User Journey

The following journey represents the primary workflow for a finance auditor conducting a single internal controls evaluation session end-to-end.

1	Authenticate The auditor accesses the application and logs in with their credentials. The system enforces role-based access. Unauthenticated users have no access to any session data or AI functionality.
2	Create Review Session The auditor creates a new session, providing a name, the process being evaluated, and the name of the process owner or local unit. The session is assigned a unique identifier and timestamped.
3	Upload Process Document The auditor uploads a PDF or DOCX file containing the process description. The system extracts the text content, runs a sanitisation pass to remove or mask identifiable personal data, and stores both the original file reference and the extracted text in the session record.
4	AI Analysis The system sends the sanitised process text to the AI model using a structured system prompt that defines the control framework, output schema, finding categories, and confidence scoring instructions. The full prompt and raw AI response are logged to the session audit record before any parsing occurs.
5	Review Findings The AI response is parsed into structured finding cards and presented to the auditor. Each card displays the finding title, category, risk level, confidence score, supporting evidence excerpt, and recommended control improvement. Findings below the confidence threshold are visually flagged as requiring mandatory human review and cannot be accepted without explicit reviewer confirmation.
6	Decision on Each Finding For each finding, the auditor selects one of three actions: Accept (the finding is included in the report as-is), Edit and Accept (the auditor modifies the recommendation text before inclusion), or Dismiss (the finding is excluded, and the auditor must provide a brief written justification). Every decision is written to the audit log with a timestamp.

7

Finalise and Export

Once all findings are reviewed, the auditor finalises the session. The system generates a structured PDF report containing the session metadata, all accepted findings with final reviewer-approved text, the AI confidence scores, supporting evidence references, and a complete audit trail appendix showing every action taken in the session.

6 Feature Requirements

Must Have (MVP)

Authentication & Access Control

Users must authenticate before accessing any feature. The system must maintain session state and enforce that each reviewer can only see sessions they have created or been assigned to. Unauthenticated access must be fully blocked at the API level.

Document Upload (PDF + DOCX)

The system must accept process description documents in PDF and DOCX formats. Text must be extracted and stored as part of the session record. File size limits and format validation must be enforced at upload.

AI-Powered Finding Generation

Given an uploaded process description, the system must invoke the AI model and return a structured set of findings conforming to the defined schema. The request must include a governed system prompt, and the response must be validated against the schema before being presented to the user.

Finding Review Interface

Each AI-generated finding must be presented individually with full context: category, risk level, confidence score, evidence excerpt, and recommendation. The interface must support accept, edit-and-accept, and dismiss actions per finding. Dismiss actions must require a written justification.

Confidence Threshold Enforcement

Findings with a confidence score below a configurable threshold (default: 75%) must be visually distinguished and must require explicit manual confirmation before acceptance. The threshold value must be stored in configuration, not hardcoded.

Audit Log

Every significant system event must be written to a persistent, append-only audit log: session creation, document upload, AI request initiation, AI response receipt, each reviewer decision (with action type, original AI text, final text, and note), session finalisation, and report export.

Session Management

Users must be able to create, view, and resume sessions. A session may be in one of the following states: Draft (created, no document), Analysed (AI findings generated, review pending), In Review (review in progress), Finalised (all findings decided, report exportable).

Report Export

Finalised sessions must be exportable as a structured PDF report containing session metadata, accepted findings, reviewer attribution, and an audit trail appendix.

Should Have (if time allows)

- **Finding Category Filtering:** Ability to filter the review interface by finding category (SoD, Missing Preventive Control, Missing Detective Control, etc.).
- **Session History Dashboard:** A list view of past sessions with status, date, finding count, and quick access to reports.
- **Re-analysis:** Ability to re-run AI analysis on the same document after modifying the system prompt configuration, preserving the original analysis for comparison.
- **Risk Summary:** An aggregate risk summary at the top of the review interface showing finding counts by risk level before the auditor begins review.

Out of Scope

- Multi-role permissions and role management UI
- Real-time collaboration (multiple reviewers on the same session simultaneously)
- Integration with external document management systems
- Automated finding remediation or action tracking
- Support for document formats other than PDF and DOCX
- Production-grade rate limiting and abuse prevention
- Encryption at rest for stored documents
- Multi-language support
- Mobile-optimised interface

7 AI Integration Requirements

Model & API

The system must use a capable instruction-following language model accessible via a standard API. The model must be capable of structured JSON output, multi-step reasoning over unstructured text, and reliable confidence estimation. GPT-4o is the reference model for this prototype.

Data Residency Note: In a production deployment, Azure OpenAI Service would be strongly preferred. Azure OpenAI processes data within a designated Azure region under enterprise data processing agreements, ensuring no customer data is used for model training and that data does not leave the organisational tenant. The prototype uses the standard OpenAI API with explicit data retention opt-out.

Prompt Architecture

The AI integration must be structured with two prompt components:

- **System Prompt:** Defines the AI's role (internal controls expert), the evaluation framework (SoD, preventive/detective/corrective controls), the required output schema (strict JSON), the confidence scoring methodology, and explicit instructions to flag low-confidence findings rather than guessing. The system prompt must be versioned and stored with each session audit record.
- **User Prompt:** Contains the sanitised process description text and any session-level context (process name, unit type). The full user prompt must be stored in the session audit log before the API call is made.

Hallucination Mitigation

The following strategies must be implemented to reduce the impact of AI hallucinations:

- Confidence scores are required for every finding. Findings below threshold are blocked from silent acceptance.
- The system prompt must include worked examples of valid and invalid findings to calibrate the model's output quality.
- Evidence excerpts are required for every finding. A finding without a supporting text passage is invalid and must not be displayed.
- The raw AI response is stored and presented to reviewers on request, enabling human verification of the AI's reasoning.
- Human review is mandatory for every finding. No findings are automatically accepted or included in reports without explicit reviewer action.

Output Validation

The AI response must be validated against the defined findings schema before any findings are presented to the user. Invalid or malformed responses must be logged as errors, and the user must

be notified that analysis failed rather than receiving partial or corrupted output. The validation must check for required fields, field type correctness, valid enum values, and confidence score range (0.0–1.0).

8 Governance & Compliance Requirements

Human-in-the-Loop as a Requirement, Not a Feature

In finance and audit contexts, AI outputs carry governance risk if acted upon without human verification. ControlGuard AI treats human review not as an optional enhancement but as a mandatory architectural constraint. No AI-generated finding may appear in a finalised report without a logged, attributed human decision to include it.

Audit Trail Requirements

- All AI inputs (system prompt, user prompt, document text) must be stored before the AI call is made, so that the trail remains complete even if the call fails.
- All AI raw outputs must be stored, including the full JSON response and any error messages, before any parsing or transformation is applied.
- All reviewer actions must be stored with: action type, original AI text, final text after any edits, reviewer identity, reviewer note (if provided), and precise timestamp.
- Session finalisation must be a discrete, logged event that locks the session against further modification.
- The audit log must be append-only within the application. No UI feature may permit deletion or modification of existing log entries.
- The exported report must include a complete audit trail appendix, not just the final accepted findings.

AI Output Attribution

All exported reports must clearly attribute findings to AI-assisted analysis and identify the human reviewer who made the acceptance decision. Reports must include a disclosure statement indicating that findings were generated with AI assistance and reviewed by a qualified human auditor.

Data Handling

- Process documents must be treated as potentially sensitive. They must not be transmitted to external services without a sanitisation step.
- The sanitisation function must be a discrete, testable component that can be audited and improved independently of the AI call logic.
- OpenAI API calls must be made with data retention disabled where the API supports this configuration.
- Mock data used in the prototype must be clearly labelled as synthetic and must not use real names, real identifiers, or real financial figures.
- Session data must not be accessible to users other than the session creator without explicit access grants.

9 Security Requirements

Authentication

All application routes must require a valid authenticated session. JWT-based authentication with appropriate expiry must be implemented. Unauthenticated requests to any API endpoint must return 401.

Authorisation

Access to session data must be scoped to the session owner. API endpoints that return or modify session data must validate that the requesting user is authorised for that session.

Input Validation

All user-supplied inputs must be validated for type, length, and format before processing. File uploads must be validated for type and size. API request bodies must be schema-validated before reaching business logic.

API Key Protection

The OpenAI API key must be stored as an environment variable and must never be exposed in client-side code, version control, or logs.

Sensitive Data in Logs

Log entries must not contain raw document text beyond the designated session storage. Reviewer notes and finding text must be treated as potentially sensitive in log output.

Dependency Security

Dependencies must be pinned to specific versions. The project must not include known-vulnerable packages at the time of delivery.

Error Handling

Application errors must not expose internal implementation details, stack traces, or database query structures in API responses. Error responses must use generic messages for external consumption while full detail is written to server-side logs.

10 AI Findings Schema

The AI model must return findings in the following JSON structure. This schema is the contract between the AI prompt layer and the application. Any deviation from this schema must be caught by validation and treated as an error.

Top-Level Response Object

Field	Type	Description
session_id	string (UUID)	The session this analysis belongs to. Injected by the application, not generated by AI.
analysis_timestamp	string (ISO 8601)	UTC timestamp of when the analysis was generated.
document_metadata	object	Metadata about the analysed document. See sub-schema below.
findings	array of Finding	Ordered list of control gap findings. May be empty if no gaps are identified.
summary	object	Aggregate summary of findings. See sub-schema below.

document_metadata Object

Field	Type	Description
filename	string	Original filename of the uploaded document.
process_name	string	Name of the process being evaluated (provided by user at session creation).
process_owner	string	Name of the process owner or local unit (provided by user).
word_count	integer	Approximate word count of the extracted text. Used for analysis quality context.

Finding Object

Each element in the findings array must conform to the following structure. All fields are required unless marked optional.

Field	Type / Enum	Description
finding_id	string (UUID)	Unique identifier for this finding. Generated by AI or application.

sequence	integer	Display order (1-based). AI should order by descending risk level.
category	enum (see below)	The control framework category this finding belongs to.
title	string (max 80 chars)	A concise, specific title for the finding. Not a generic label.
description	string	A clear explanation of the identified gap, including why it is a risk.
affected_process_step	string	The specific step or activity in the process where the gap exists.
risk_level	enum: critical high medium low	Severity of the risk if the gap is not addressed.
confidence_score	float (0.0 – 1.0)	The AI's confidence that this is a genuine finding. Must be 0.75+ for standard acceptance.
confidence_label	enum: high medium low flagged	Human-readable confidence tier. 'flagged' means mandatory human review required.
evidence_excerpt	string	A direct quote (max 200 chars) from the source document that supports this finding. REQUIRED — a finding without evidence is invalid.
recommendation	string	Specific, actionable suggested control improvement.
control_type_suggested	enum: preventive detective corrective multiple	The type of control improvement being recommended.
requires_human_review	boolean	True if confidence_score < threshold or if the finding is complex. Blocks silent acceptance.
review_status	enum: pending accepted edited dismissed	Set by the application, not AI. Initial value is always 'pending'.
reviewer_decision	object null	Populated by the application when the reviewer acts. Null until a decision is made.

Finding Category Enum Values

Value	Description
-------	-------------

segregation_of_duties	A single individual or role has control over an entire critical process with no independent oversight.
missing_preventive_control	A control that should stop an error or irregularity before it occurs is absent from the process.
missing_detective_control	A control that should identify errors after they occur (e.g. reconciliation, review) is absent.
missing_corrective_control	The process lacks a defined remediation procedure for when an error or exception is identified.
excessive_access	An individual or role has access to systems, data, or transactions beyond what their function requires.
documentation_gap	A critical process step lacks documentation, making it unauditable or inconsistently applied.
manual_process_risk	A manual, spreadsheet-based, or undocumented process step creates unacceptable error or fraud risk.
approval_chain_weakness	An approval or authorisation step is missing, bypassed, or insufficiently independent.

reviewer_decision Object

Field	Type	Description
decided_by	string	Identity of the reviewer who made the decision.
decided_at	string (ISO 8601)	UTC timestamp of the decision.
action	enum: accepted edited dismissed	The decision made.
original_recommendation	string	The AI's original recommendation text, preserved immutably.
final_recommendation	string	The text that will appear in the report. Equals original if accepted unchanged.
reviewer_note	string null	Required if action is 'dismissed'. Optional for accepted or edited findings.

summary Object

Field	Type	Description
total_findings	integer	Total number of findings generated.
by_risk_level	object	Count of findings keyed by risk level: { critical, high, medium, low }.

by_category	object	Count of findings keyed by category enum value.
flagged_for_review_count	integer	Number of findings with requires_human_review: true.
overall_risk_assessment	string (max 300 chars)	A brief AI-generated summary of the overall risk posture of the process.
key_themes	array of string	Up to 3 recurring themes or patterns across the findings.

11 Audit Log Schema

Every significant system event must produce an audit log entry. Log entries are immutable once written. The following schema applies to all entries.

Field	Type	Description
log_id	string (UUID)	Unique identifier for this log entry.
session_id	string (UUID)	The session this event belongs to.
event_type	enum (see below)	The category of event being recorded.
event_timestamp	string (ISO 8601)	UTC timestamp of the event.
actor	string	The identity of the user or system component that triggered the event.
payload	object	Event-specific data. Schema varies by event_type.
outcome	enum: success failure partial	Whether the event completed successfully.
error_detail	string null	Error message if outcome is failure. Null otherwise.

Event Type Enum Values

Event Type	Trigger	Key Payload Fields
session_created	User creates a new session	session_name, process_name, process_owner
document_uploaded	User uploads a process document	filename, file_size, word_count, sanitisation_applied
ai_request_initiated	AI API call is dispatched	system_prompt_version, user_prompt_hash, model, temperature
ai_response_received	AI API call returns	response_id, finding_count, flagged_count, raw_response_stored_at
finding_reviewed	User acts on a finding	finding_id, action, confidence_score, had_edit, note_provided
session_finalised	User finalises the session	total_findings, accepted_count, dismissed_count, edited_count

report_exported	User exports the PDF report	report_filename, included_finding_count, exported_by
auth_event	Login or logout occurs	event_subtype (login logout failed_login), user_agent

12 Success Criteria

Functional Completeness

- A user can log in, create a session, upload a PDF or DOCX document, trigger AI analysis, review all findings, and export a finalised PDF report — end-to-end without errors.
- AI findings conform to the defined schema. An invalid finding cannot be displayed to the user.
- Findings below the confidence threshold are visually differentiated and cannot be accepted without explicit manual action.
- Every reviewer action produces an audit log entry that persists beyond the session.
- The exported report contains both accepted findings and the audit trail appendix.

Governance Quality

- The AI prompt captures the system prompt version used for each analysis session.
- Raw AI responses are stored before parsing. If parsing fails, the raw response is preserved for debugging.
- No finding appears in an exported report without a logged acceptance decision.
- Dismissed findings are preserved in the audit log with reviewer justification.

Engineering Quality

- The codebase is structured such that the AI prompt layer, the parsing/validation layer, and the review workflow layer are clearly separated.
- The confidence threshold is a configuration value, not hardcoded.
- Error states (failed AI call, invalid schema, upload failure) are handled gracefully and displayed to the user without exposing internal details.
- The project README contains complete setup and run instructions.
- An AI usage report documents the prompts used, the areas where AI-generated code was modified, and the validation approach applied.

13 Out of Scope

The following items are explicitly out of scope for this prototype. Where relevant, the architectural approach for implementing them in a production system is noted to demonstrate awareness.

Multi-role permissions

Only a single authenticated user role is required. A production system would distinguish between auditor, reviewer, and admin roles with different access levels.

Real-time collaboration

A single reviewer per session is assumed. Production would require conflict resolution and concurrent access handling.

Encryption at rest

Documents and session data are stored without encryption at rest in the prototype. Production would require encrypted storage, particularly for anything that might contain personally identifiable information.

Document format support beyond PDF and DOCX

No support for Excel, plain text, or image-based documents.

Integration with external systems

No integration with document management, ERP, or audit management systems.

Rate limiting and abuse prevention

API rate limiting is not implemented. A production deployment would require this to prevent both abuse and inadvertent cost overruns on AI API calls.

Localisation

The interface is English-only. The Frankfurt context would likely require German language support in production.

Mobile interface

The application is designed for desktop use only.

Automated remediation tracking

The system surfaces findings but does not track whether they have been remediated. Production would link findings to action items and track closure.

14 Assumptions & Open Questions

Assumptions

- Process description documents are text-based (not scanned images). OCR is not required for the prototype.
- A single user session at a time is sufficient. Concurrent session handling is not a requirement for the prototype.
- Mock data is acceptable. No real Church financial data will be used.
- The confidence threshold default of 75% is appropriate for the prototype and should be validated with domain experts before production use.
- English-language process documents are the primary input format.
- The evaluating team will have access to the source code repository. Security of the repository itself is the candidate's responsibility during assessment.
- The OpenAI API key is provided by the candidate and is not required from the assessment panel.

Open Questions for Stakeholder Validation

- What is the typical length and format of process description documents used by the Frankfurt team? This affects context window sizing and chunking strategy.
- Are there specific Church-mandated control categories or frameworks beyond the generic SoD / preventive / detective / corrective taxonomy defined here?
- What is the expected output format for official findings reports? Is there an existing template the system should align with?
- Who is the designated reviewer of AI outputs in the real workflow — the same auditor who uploads the document, or a separate supervisor?
- Is there an existing audit management system that finalised sessions would need to integrate with in production?
- What data residency requirements apply to this type of process documentation in the Frankfurt jurisdiction?